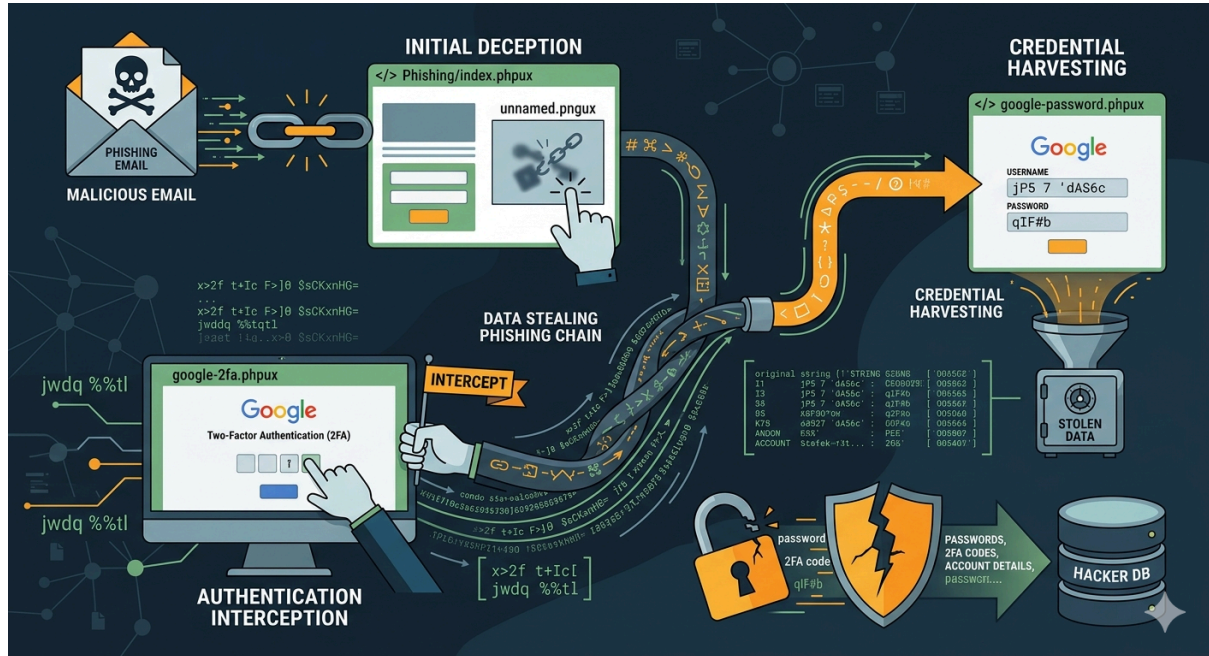


Campagne de Phishing Google

Illustration de la campagne :



Contexte :

La fausse cible est : microsoftteams798@gmail.com

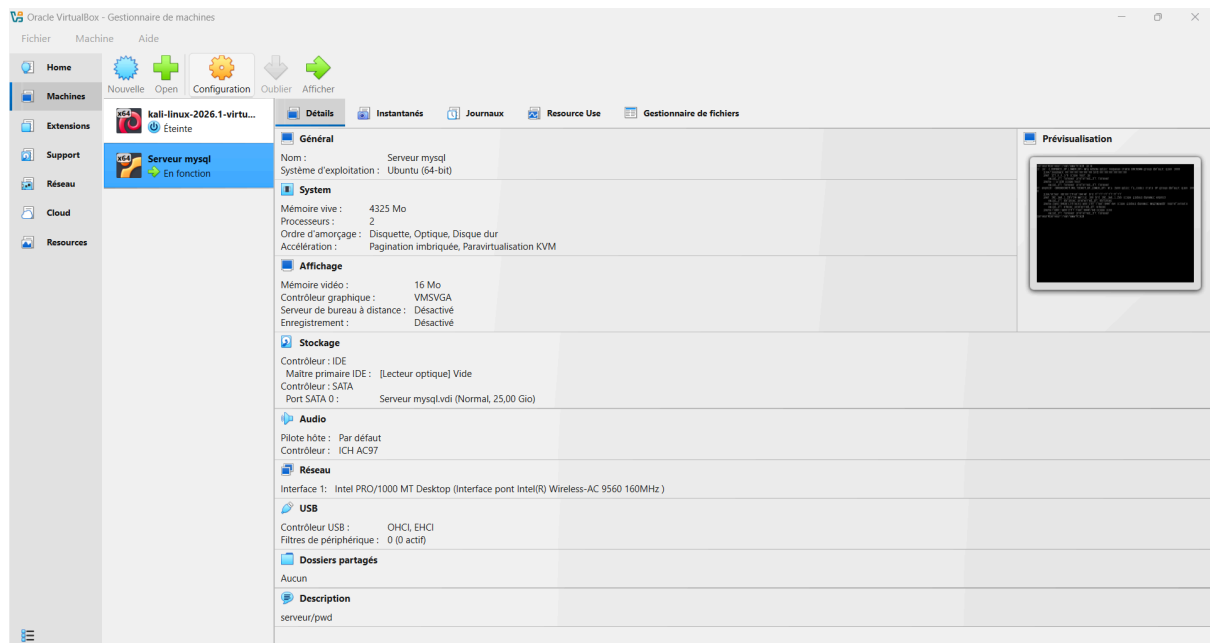
Il s'agit d'un faux compte Google créé pour cette campagne de Phishing.

On va partir du principe que j'ai envoyé un mail à la cible et il y a un URL :

<http://192.168.1.237/> qui redirige la cible vers une page de connexion. Cette page de connexion est hébergée en local avec VirtualBox dans le Serveur Web Ubuntu créé par moi.

On peut très bien utiliser [Render.com](https://render.com) qui va déployer les fausses pages en ligne.

Voici un exemple d'URL : <https://account-google.onrender.com>



Voici le Serveur web dans lequel Apache, PHP, MySQL et phpmyadmin ont été installé :

```
serveur@serveur:/var/www/html$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:ef:84:4f brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.237/24 metric 100 brd 192.168.1.255 scope global dynamic enp0s3
        valid_lft 85710sec preferred_lft 85710sec
    inet6 2a02:8428:c97:5c01:a00:27ff:feef:844f/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 676sec preferred_lft 676sec
    inet6 fe80::a00:27ff:feef:844f/64 scope link
        valid_lft forever preferred_lft forever
serveur@serveur:/var/www/html$
```

Sur l'interface phpmyadmin, j'ai créer les bases de données et leurs tables :

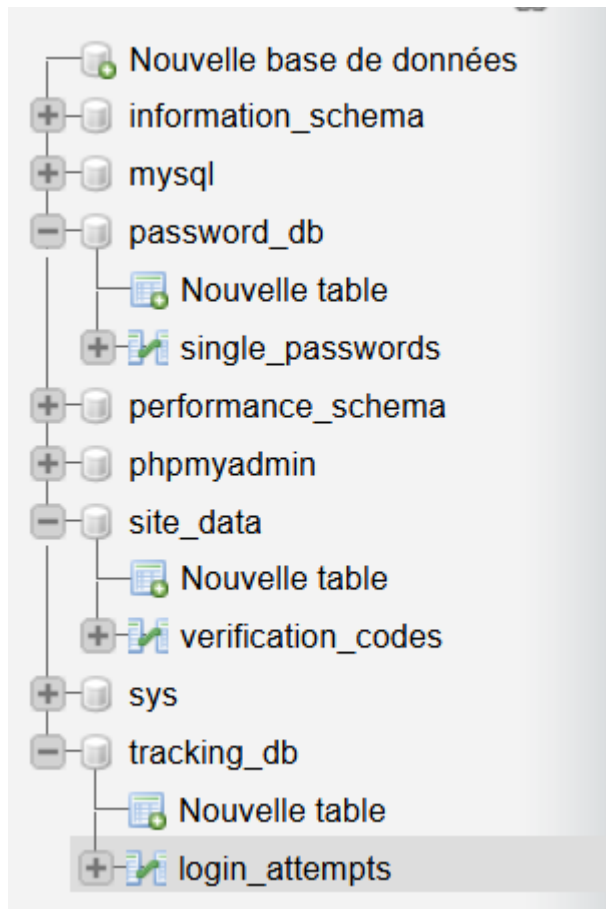
Voici les commandes SQL :

```
-- Base 1 : enregistrement des e-mails
CREATE DATABASE tracking_db;
USE tracking_db;
CREATE TABLE login_attempts (
  id INT AUTO_INCREMENT PRIMARY KEY,
  email VARCHAR(255) NOT NULL,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

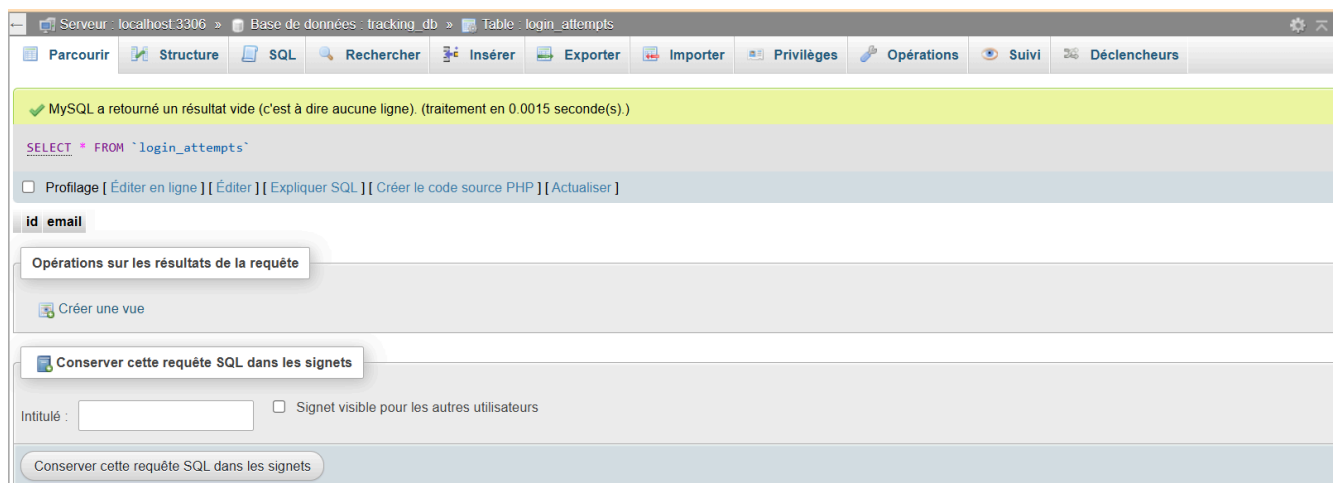
```
-- Base 2 : enregistrement des mots de passe
CREATE DATABASE password_db;
USE password_db;
CREATE TABLE single_passwords (
  id INT AUTO_INCREMENT PRIMARY KEY,
  password VARCHAR(255) NOT NULL,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

```
-- Base 3 : enregistrement des codes 2FA
CREATE DATABASE site_data;
USE site_data;
CREATE TABLE verification_codes (
  id INT AUTO_INCREMENT PRIMARY KEY,
  code CHAR(6) NOT NULL,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

Voici l'interface phpmyadmin :



Voici la base de données tracking_db :



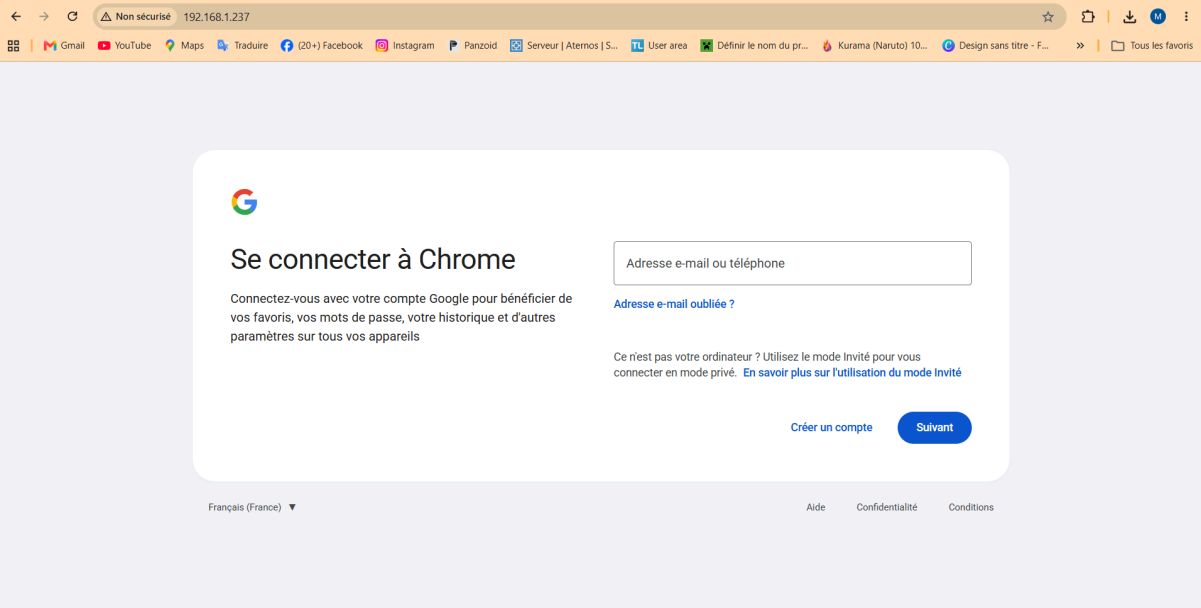
Voici la base de données password_db :

The screenshot shows the phpMyAdmin interface for the 'password_db' database, specifically the 'single_passwords' table. The top navigation bar includes links for 'Parcourir', 'Structure', 'SQL', 'Rechercher', 'Insérer', 'Exporter', 'Importer', 'Privileges', 'Opérations', 'Suivi', and 'Déclencheurs'. A green status bar at the top indicates 'MySQL a retourné un résultat vide (c'est à dire aucune ligne). (traitement en 0.0016 seconde(s)).' Below this, the SQL query 'SELECT * FROM `single\_passwords`' is displayed. A toolbar offers options like 'Profilage', 'Éditer en ligne', 'Éditer', 'Expliquer SQL', 'Créer le code source PHP', and 'Actualiser'. The table structure is shown with columns 'id' and 'password'. Below the table, there are sections for 'Opérations sur les résultats de la requête' (with a 'Créer une vue' button) and 'Conserver cette requête SQL dans les signets' (with a form for 'Intitulé' and a checkbox for 'Signet visible pour les autres utilisateurs').

Voici la base de données site_data :

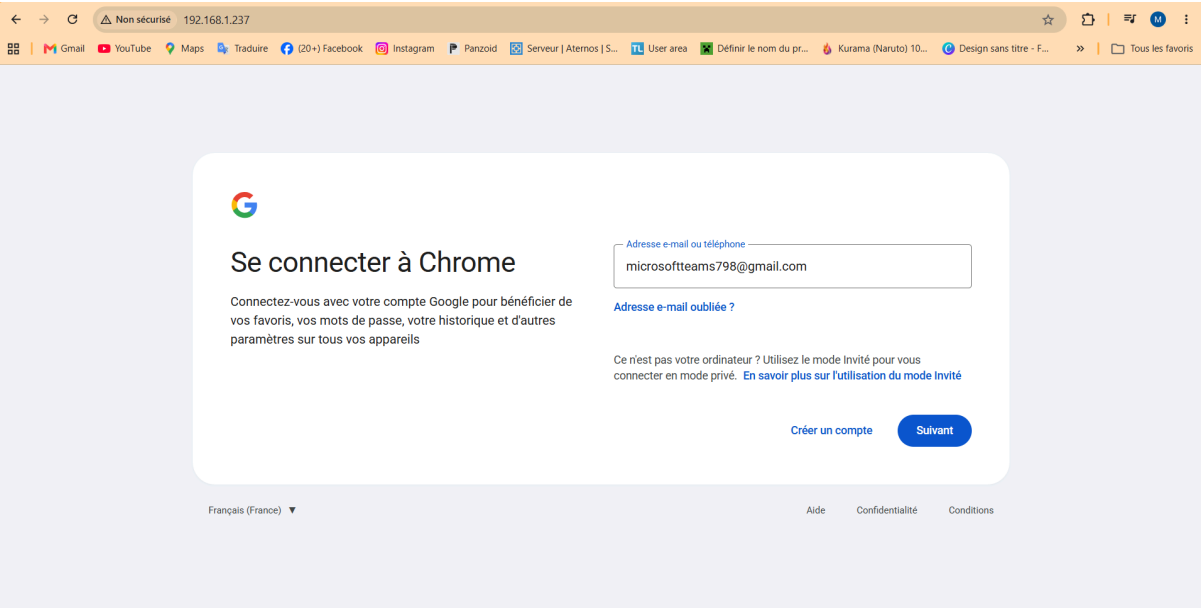
The screenshot shows the phpMyAdmin interface for the 'site_data' database, specifically the 'verification_codes' table. The top navigation bar includes links for 'Parcourir', 'Structure', 'SQL', 'Rechercher', 'Insérer', 'Exporter', 'Importer', 'Privileges', 'Opérations', 'Suivi', and 'Déclencheurs'. A green status bar at the top indicates 'MySQL a retourné un résultat vide (c'est à dire aucune ligne). (traitement en 0.0021 seconde(s)).' Below this, the SQL query 'SELECT * FROM `verification\_codes`' is displayed. A toolbar offers options like 'Profilage', 'Éditer en ligne', 'Éditer', 'Expliquer SQL', 'Créer le code source PHP', and 'Actualiser'. The table structure is shown with columns 'id', 'code', and 'created_at'. Below the table, there are sections for 'Opérations sur les résultats de la requête' (with a 'Créer une vue' button) and 'Conserver cette requête SQL dans les signets' (with a form for 'Intitulé' and a checkbox for 'Signet visible pour les autres utilisateurs').

La cible a cliqué sur le lien présent dans le mail que je lui ai envoyé et elle a été redirigé sur cette fausse page de connexion Google que j'ai créé :



This is a screenshot of a web browser displaying a fake Google login page. The browser's address bar shows 'Non sécurisé' (Not secure) and the IP address '192.168.1.237'. The page features the Google logo at the top left. Below it, the heading 'Se connecter à Chrome' (Sign in to Chrome) is followed by the text: 'Connectez-vous avec votre compte Google pour bénéficier de vos favoris, vos mots de passe, votre historique et d'autres paramètres sur tous vos appareils' (Sign in with your Google account to benefit from your favorites, passwords, history, and other settings across all your devices). To the right of this text is a text input field labeled 'Adresse e-mail ou téléphone' (Email or phone number). Below the input field is a link that says 'Adresse e-mail oubliée ?' (Forgot email address?). Further down, there is a line of text: 'Ce n'est pas votre ordinateur ? Utilisez le mode Invité pour vous connecter en mode privé. En savoir plus sur l'utilisation du mode Invité' (Is this not your computer? Use Guest mode to sign in privately. Learn more about Guest mode). At the bottom right of the main content area are two buttons: 'Créer un compte' (Create account) and 'Suivant' (Next). At the very bottom of the page, there is a language selector set to 'Français (France)' and three links: 'Aide' (Help), 'Confidentialité' (Privacy), and 'Conditions' (Terms).

La cible rentre son adresse mail dans la zone de texte :



This is a second screenshot of the same fake Google login page, but now the email address 'microsoftteams798@gmail.com' has been entered into the 'Adresse e-mail ou téléphone' input field. All other elements of the page, including the Google logo, the 'Se connecter à Chrome' heading, the descriptive text, the 'Adresse e-mail oubliée ?' link, the Guest mode notice, the 'Créer un compte' and 'Suivant' buttons, and the footer with the language selector and links, remain identical to the first screenshot.

Quand la cible clique sur le bouton : Suivant, voici ce qui se passe et que la cible ne voit pas. Sur la base de données : tracking_db, dans la table login_attempts. J'ai récupéré l'adresse mail de la cible :

The screenshot shows a database management tool interface. At the top, it indicates the server is localhost:3306, the database is tracking_db, and the table is login_attempts. A toolbar contains various actions like Parcourir, Structure, SQL, Rechercher, Insérer, Exporter, Importer, Privileges, Opérations, Suivi, and Déclencheurs. A green status bar confirms the display of lines 0-0 (total of 1) in 0.0016 seconds. The SQL query shown is `SELECT * FROM `login_attempts``. Below the query, there are options for Profilage, Éditer en ligne, Éditer, Expliquer SQL, Créer le code source PHP, and Actualiser. A filter section shows 'Tout afficher', 'Nombre de lignes: 25', and a search box 'Chercher dans cette table'. Under the '+ Options' section, a dropdown menu shows 'id' and 'email'. The table data shows one row with 'id' 16 and 'email' 'microsoftteams798@gmail.com'. At the bottom, there are more options like 'Tout cocher', 'Avec la sélection: Éditer, Copier, Supprimer, Exporter', and another filter section identical to the one above.

La cible sera redirigé vers cette autre page de connexion où la cible devra entrer son mot de passe :

The screenshot shows a web browser window with the address bar displaying '192.168.1.237/google-password.php?email=microsoftteams798%40gmail.com'. The page has a light blue background. In the center, there is a white login card. The card features the Google logo at the top left, followed by the word 'Bienvenue'. Below this, there is a dropdown menu showing 'microsoftteams798@gmail.com'. To the right of the dropdown, there is a text input field with the placeholder 'Saisissez votre mot de passe'. Below the input field, there is a checkbox labeled 'Afficher le mot de passe'. At the bottom right of the card, there is a link 'Mot de passe oublié ?' and a blue button labeled 'Suivant'. At the very bottom of the page, there is a footer with 'Français (France)' on the left and 'Aide', 'Confidentialité', and 'Conditions' on the right.

La cible rentre son mot de passe :

Non sécurisé 192.168.1.237/google-password.php?email=microsoftteams798%40gmail.com

G

Bienvenue

microsoftteams798@gmail.com

Saisissez votre mot de passe

.....

☐ Afficher le mot de passe

Mot de passe oublié ? Suivant

Français (France)

Aide Confidentialité Conditions

Quand la cible clique sur le bouton : Suivant, voici ce qui se passe et que la cible ne voit pas. Sur la base de données : password_db, dans la table single_passwords. J'ai récupéré le mot de passe de la cible :

Serveur : localhost:3306 » Base de données : password_db » Table : single_passwords

Parcourir Structure SQL Rechercher Insérer Exporter Importer Privileges Opérations Suivi Déclencheurs

✓ Affichage des lignes 0 - 0 (total de 1, traitement en 0.0031 seconde(s).)

SELECT * FROM `single\_passwords`

☐ Profilage [Éditer en ligne] [Éditer] [Expliquer SQL] [Créer le code source PHP] [Actualiser]

☐ Tout afficher | Nombre de lignes : 25 | Filtrer les lignes: Chercher dans cette table

+ Options

id password

☐ Éditer Copier Supprimer 5 microsoft118

Tout cocher Avec la sélection : Éditer Copier Supprimer Exporter

☐ Tout afficher | Nombre de lignes : 25 | Filtrer les lignes: Chercher dans cette table

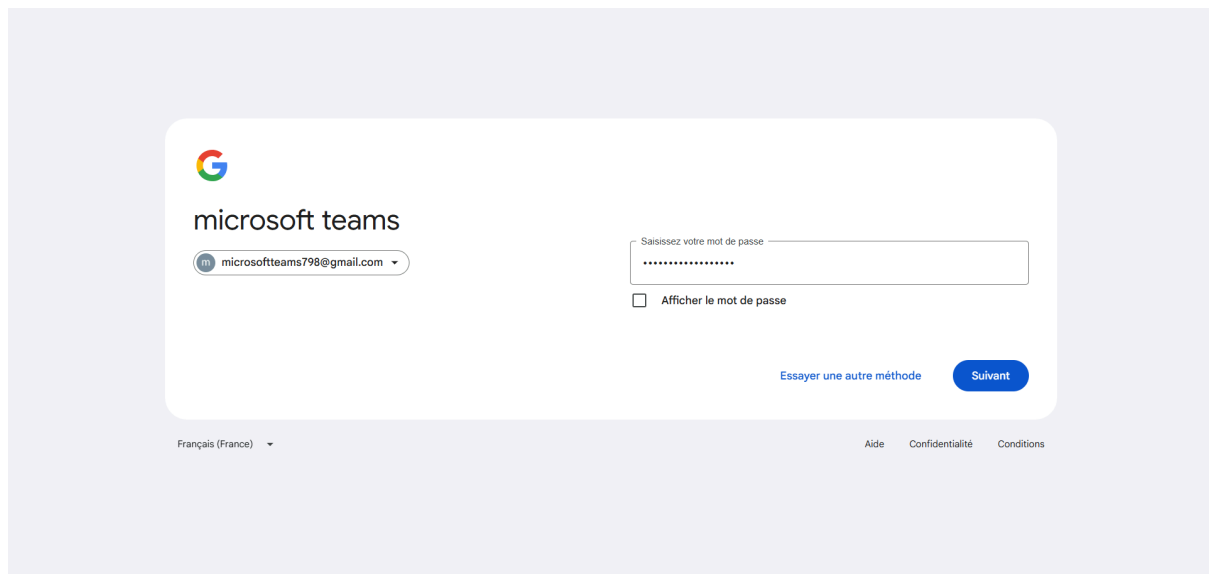
La cible sera redirigé vers cette autre page de connexion à deux étapes où la cible devra entrer son code que google :

The screenshot shows a web browser window with the address bar displaying a URL: 192.168.1.237/google-2fa.php?email=microsoftteams798%40gmail.com. The browser's address bar also shows "Non sécurisé". The browser's toolbar includes icons for Gmail, YouTube, Maps, Traduire, Facebook, Instagram, Panzoid, Serveur | Aternos | S..., User area, Définir le nom du pr..., Kurama (Naruto) 10..., Design sans titre - F..., and Tous les favoris.

The main content area displays the Google logo at the top left. Below it, the heading "Validation en deux étapes" is followed by the text: "Afin de protéger votre compte, Google veut s'assurer que c'est bien vous qui essayez de vous connecter". Below this text is a dropdown menu showing the email address "microsoftteams798@gmail.com". To the right of the dropdown menu, there is a text input field labeled "Saisissez le code" with the text "G-" inside. Above the input field, there is a message: "Un SMS contenant un code de validation à six chiffres a été envoyé au .. 43". Below the input field, there is a checkbox labeled "Ne plus me demander sur cet appareil" which is checked. At the bottom of the form, there are three buttons: "Renvoyer", "Essayer une autre méthode", and "Suivant". At the very bottom of the page, there is a language selector showing "Français (France)" and links for "Aide", "Confidentialité", and "Conditions".

Ensuite je me connecte avec l'adresse mail et le mot de passe de la cible en direct.

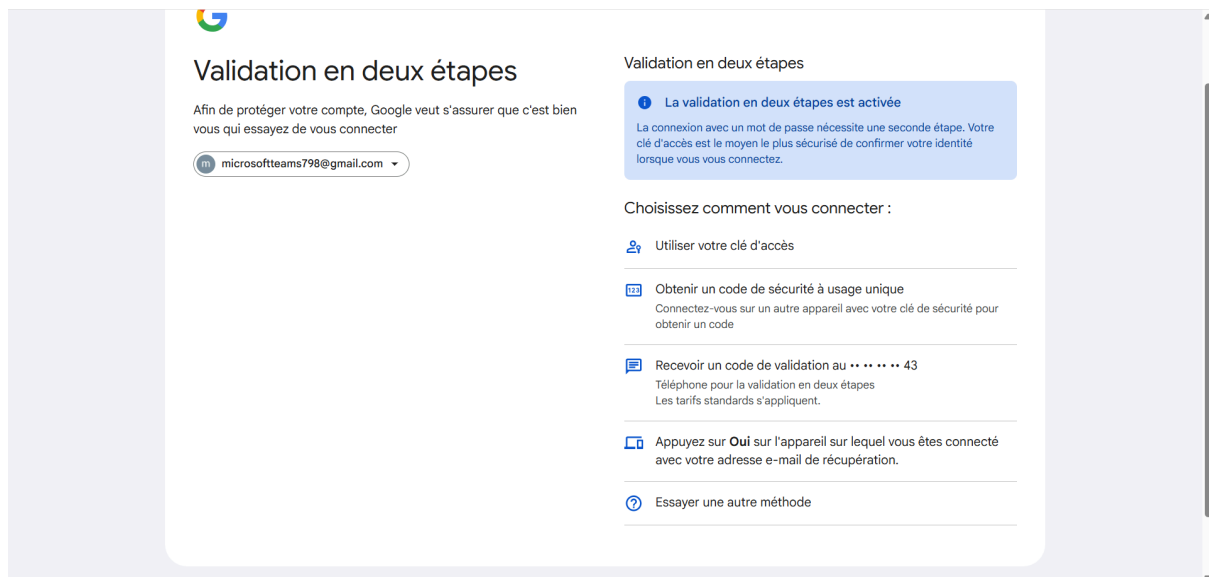
The screenshot shows the Google "Connexion" page. The Google logo is at the top left. Below it, the heading "Connexion" is followed by the text: "avec votre compte Google. Ce compte sera disponible pour d'autres applis Google dans le navigateur." To the right of this text is a text input field labeled "Adresse e-mail ou téléphone" with the email address "microsoftteams798@gmail.com" inside. Below the input field, there is a link labeled "Adresse e-mail oubliée ?". Below the link, there is a message: "Ce n'est pas votre ordinateur ? Utilisez le mode Invité pour vous connecter en mode privé. En savoir plus sur l'utilisation du mode Invité". At the bottom of the form, there are two buttons: "Créer un compte" and "Suivant". At the very bottom of the page, there is a language selector showing "Français (France)" and links for "Aide", "Confidentialité", and "Conditions".



Pour ce test j'ai utilisé le vrai mot de passe de ce compte qui est différent de celui de la base de données, c'est pour ça qu'il est plus long. Mais il faut rentrer le même mot de passe récupéré dans la base de données.

Pour une question de confidentialité, je ne vous montrais pas le vrai mot de passe même si c'est un compte Google de test.

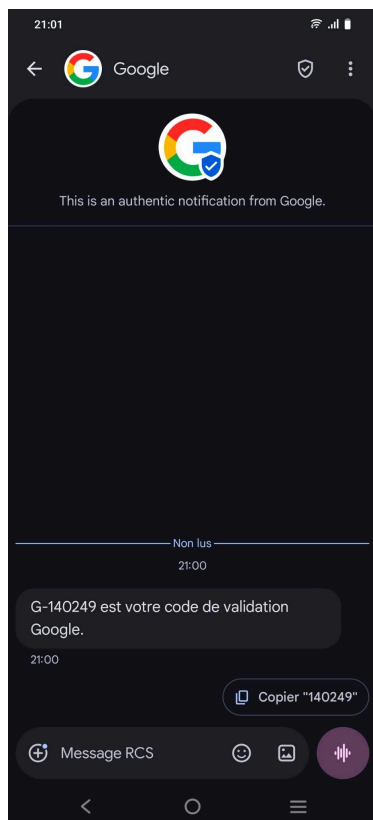
Je suis redirigé vers cette page qui me demande de choisir une option :



La cible attend de recevoir le code par SMS.

Alors je choisis l'option : Recevoir un code de validation au ... 43

Voici le SMS avec le code envoyé par Google :



La cible entre son code dans la zone texte :

Validation en deux étapes

Afin de protéger votre compte, Google veut s'assurer que c'est bien vous qui essayez de vous connecter

microsoftteams798@gmail.com

Saisissez le code

G- 140249

☒ Ne plus me demander sur cet appareil

Renvoyer Essayer une autre méthode Suivant

Quand la cible clique sur le bouton : Suivant, voici ce qui se passe et que la cible ne voit pas. Sur la base de données : site_data, dans la table verification_codes. J'ai récupéré le code de la cible :

✓ Affichage des lignes 0 - 0 (total de 1, traitement en 0.0024 seconde(s).)

SELECT * FROM `verification\_codes`

Profilage [Éditer en ligne] [Éditer] [Expliquer SQL] [Créer le code source PHP] [Actualiser]

Tout afficher Nombre de lignes : 25 Filtrer les lignes: Chercher dans cette table

+ Options

	id	code	created_at
☐ Éditer Copier Supprimer	2	140249	2026-06-02 19:05:57

Tout cocher Avec la sélection : Éditer Copier Supprimer Exporter

Tout afficher Nombre de lignes : 25 Filtrer les lignes: Chercher dans cette table

Je rentre le code récupéré pour prendre le contrôle du compte Google de la cible et je change le mot de passe. Au même moment la cible sera redirigé vers cette fausse page de recherche google :

